Validación del prototipo Aurora

Plan e informe de pruebas, evaluación de seguridad y evaluación de usabilidad

Documento de la Fase 4 · Objetivo específico 4

Leydy Yohana Macareo Fuentes

Programa de Ingeniería de Sistemas, Universidad Autónoma de Bucaramanga

Proyecto de Grado II

Directora: Verónica Chajín Ortiz

Noviembre de 2026

Control del documento

Campo	Valor
Proyecto	Aurora: prototipo de aplicación móvil de uso discreto para el acceso a información, la orientación y el registro seguro ante la violencia de género en mujeres de Santander
Documento	Validación del prototipo (Fase 4)
Versión del documento	1.0
Fecha	Noviembre de 2026
Autora	Leydy Yohana Macareo Fuentes
Directora	Verónica Chajín Ortiz
Versión del prototipo evaluada	v0.3.4-trl4 (etiqueta del repositorio github.com/leydymf/aurora-app)
Normas de referencia	ISO/IEC/IEEE 29119-3 para la documentación de pruebas; ISO/IEC 25010 para las características de calidad evaluadas; OWASP MASVS 2.1.0 y MASTG 2.0.0 para la evaluación de seguridad; ISO 9241-11 para la usabilidad
Historial	1.0: versión inicial. Reúne el plan de pruebas, el informe de pruebas técnicas y de seguridad y el protocolo de evaluación de usabilidad del proyecto, actualizados a la versión final del prototipo.

Tabla de contenido

Control del documento....2
1. Propósito y alcance....4
2. Actividades de la fase....4
3. Plan de pruebas....5
3.1 Elementos probados y tipos de prueba....5
3.2 Entorno de pruebas....6
3.3 Criterios de aprobación....6
3.4 Casos de prueba....7
3.5 Elementos no probados y riesgos....9
4. Pruebas técnicas....9
4.1 Funcionalidad....9
4.2 Rendimiento....11
4.3 Compatibilidad....12
5. Evaluación de seguridad....13
5.1 Marco y alcance....13
5.2 Método....13
5.3 Resultados....14
5.4 Protección de datos personales y referencia a ISO/IEC 27001....16
6. Evaluación de usabilidad....17
6.1 Instrumento y meta....17
6.2 Participantes....18
6.3 Materiales y desarrollo de la sesión....18
6.4 Cálculo e interpretación del puntaje....19
6.5 Resultados....20
7. Nivel de madurez alcanzado....21
8. Conclusiones y pendientes antes de un piloto....22
Referencias....24
Apéndice A. Instrumentos de la evaluación de usabilidad....26
Instrumento S1. Consentimiento informado....26
Instrumento S2. Tarjeta de datos de prueba....27
Instrumento S3. Tareas....28
Instrumento S4. Cuestionario....29
Anexos digitales....31

1. Propósito y alcance

Este documento reúne la validación del prototipo Aurora, que corresponde al cuarto objetivo específico del proyecto: validar el prototipo mediante pruebas técnicas y evaluación de usabilidad para su adecuación al contexto de mujeres del departamento de Santander. Describe las actividades y los criterios de validación de la fase, el plan de pruebas con que se verificó el prototipo, los resultados de las pruebas de funcionalidad, rendimiento y compatibilidad, la evaluación de seguridad con el marco OWASP MAS y la evaluación de usabilidad con la escala SUS, y cierra con el nivel de madurez alcanzado y los pendientes antes de un piloto.

El objeto de la validación es la versión final del prototipo, v0.3.4-trl4, con la aplicación Android, el panel web de administración y los servicios en la nube que los conectan. El detalle técnico de cada prueba, con sus evidencias, está en el repositorio del proyecto: el plan de pruebas y sus resultados en PLAN_PRUEBAS.md y RESULTADOS_PRUEBAS.md, y la evaluación de seguridad completa en INFORME_SEGURIDAD_OWASP.md, con sus evidencias en la carpeta evidencias-owasp. Este documento resume esos registros y presenta lo que un lector necesita para juzgar la validación sin leerlos.

2. Actividades de la fase

La Fase 4 es el ciclo de evaluación y realimentación del diseño de investigación-acción del proyecto. Comprende seis actividades: el diseño del plan de pruebas técnicas y de seguridad (A4.1), la ejecución de pruebas de funcionalidad de caja negra (A4.2), la ejecución de pruebas de seguridad (A4.3), la evaluación de usabilidad (A4.4), el análisis de resultados y la documentación de ajustes (A4.5) y la implementación de los ajustes finales y la entrega (A4.6). Con ellas el prototipo alcanza el nivel de madurez tecnológica TRL 4: sistema validado en entorno controlado.

La validación usa cuatro criterios. La funcionalidad se verifica por la cobertura de los requerimientos de la Fase 1. La seguridad se evalúa con el marco OWASP MAS y frente a los principios de la Ley 1581 de 2012 y la norma ISO/IEC 27001. La usabilidad se mide con la System Usability Scale, con una meta de 75 o más sobre 100, en un entorno controlado y con datos simulados. La pertinencia contextual se revisa por la adecuación del lenguaje, el diseño y las funciones al contexto de Santander.

La evaluación de seguridad completa se hizo sobre la versión v0.3.0 y sus correcciones se verificaron en la v0.3.1; las versiones siguientes, hasta la v0.3.4, se revisaron control por control. La evaluación de usabilidad se hizo con diez personas mayores de edad y no con mujeres en situación de violencia, por las razones éticas expuestas en la Fase 1.

3. Plan de pruebas

3.1 Elementos probados y tipos de prueba

El plan sigue la estructura de documentación de pruebas de ISO/IEC/IEEE 29119-3 (International Organization for Standardization et al., 2021). Las pruebas técnicas cubren tres características de calidad de producto de ISO/IEC 25010 (International Organization for Standardization & International Electrotechnical Commission, 2023): la adecuación funcional, la eficiencia de desempeño y la compatibilidad; la seguridad se evalúa con el marco OWASP MAS y la usabilidad, con ISO 9241-11.

El plan cubre la aplicación Android en sus dos variantes (depuración y publicación), el panel web de administración y las reglas de acceso de la base de datos en la nube. Cada caso de prueba se clasifica por el tipo de verificación que exige: pruebas unitarias (PU) de la lógica de dominio y de los modelos de vista; pruebas de integración (PI) entre capas, con la base de datos cifrada y con los servicios en la nube; pruebas de caja negra (CN), que recorren la aplicación como lo haría una usuaria; pruebas de seguridad (PS), que verifican los controles de protección;

pruebas de usabilidad (US), con evaluadores y participantes; y revisión documental para el requerimiento de mantenibilidad. Las pruebas de la Fase 3 se escribieron junto con el código y las de la Fase 4 se ejecutaron sobre la versión final.

3.2 Entorno de pruebas

Las pruebas automáticas se ejecutaron en el computador de desarrollo con Gradle: las unitarias con JUnit y Robolectric, y las instrumentadas con las herramientas de prueba de Jetpack Compose en dos emuladores, uno con Android 11 (API 30) configurado como un teléfono de gama media y otro con Android 8.0 (API 26), la versión mínima que soporta la aplicación, arrancados en frío y uno a la vez. Las pruebas del panel web se ejecutaron con Vitest y las reglas de la base de datos con el emulador local de Firestore. Los recorridos manuales se hicieron en emuladores y, para la versión final, en un teléfono Xiaomi con la versión de depuración, que es la que se usa en las sesiones con participantes porque la versión de publicación todavía no permite la activación en una instalación limpia.

3.3 Criterios de aprobación

Un caso de prueba se aprueba cuando todas sus verificaciones pasan. La versión se da por aprobada cuando pasan todos los casos ejecutados, el análisis de estilo y Android Lint no reportan errores, el guardián de camuflaje no encuentra términos vedados en el instalable de publicación y las tres revisiones de cada bloque de trabajo (requerimientos, arquitectura y seguridad) quedan en «aprobado». Para los requerimientos no funcionales con metas numéricas se aplican sus límites: arranque en 3 segundos o menos e interacciones locales en 2 segundos o menos (RNF-07), contenido disponible sin conexión en 2 segundos o menos (RNF-08), ningún problema de usabilidad de gravedad mayor pendiente tras la evaluación heurística (RNF-09) y puntaje SUS promedio de 75 o más.

3.4 Casos de prueba

La Tabla 1 relaciona los 39 casos de prueba con el tipo de verificación y los requerimientos que cubren. Los casos se definieron a partir de los criterios de aceptación de los 46 requerimientos funcionales y los 11 no funcionales de la especificación. De los 46 requerimientos funcionales, 45 tienen pruebas automáticas; el restante, la sincronización diferida (RF-38), depende de la cola interna de Firestore y se verificó de forma manual.

Tabla 1

Casos de prueba del prototipo

Caso	Tipo	Requerimientos	Qué verifica
CP-01	PS	RF-01	Verificar que ícono, nombre y pantalla inicial corresponden a una app de clima sin referencias al propósito real.
CP-02	PI + CN	RF-02, RF-03, RF-04	Búsqueda y selección de ciudad, clima actual real, últimos datos sin conexión y pronóstico de 5 días.
CP-03	PS	RF-05, RF-06	Activación inicial solo con el código; exploración completa sin hallar indicios del doble fondo.
CP-04	PU + CN	RF-07	Creación de cuenta: caso válido, correo duplicado y contraseña débil.
CP-05	PU + PS	RF-08, RF-09	Creación y cambio de código: reglas de longitud y ciudad, almacenamiento no legible, confirmación de contraseña.
CP-06	CN + US	RF-10, RF-11	Cómo usar Aurora con práctica de ingreso y salida rápida; reapertura desde Ajustes.
CP-07	PI + PS	RF-12, RF-13, RF-14	Apertura por código exacto, respuesta indistinguible para otras entradas, barra limpia sin historial ni autocompletado.
CP-08	PU + CN	RF-15	Inicio de sesión: acceso correcto, error genérico, bloqueo tras 5 intentos.
CP-09	PI + US	RF-16	Salida rápida: retorno al clima en menos de 1 s, sin regreso posible por navegación ni rastro de sesión.
CP-10	CN	RF-17, RF-18	Consentimiento bloqueante sin preselección; rechazo sin recolección de datos; relectura posterior.
CP-11	CN	RF-19	Cierre de sesión y exigencia de credenciales en el siguiente acceso.
CP-12	CN + PS	RF-20	Eliminación de cuenta con doble confirmación y supresión total en dispositivo y nube.
CP-13	CN	RF-21, RF-22	Contenido completo y navegable de tipos de violencia y rutas de atención.
CP-14	PI	RF-23	Llamada con un toque mediante el marcador, sin registro en la app.

Caso	Tipo	Requerimientos	Qué verifica
CP-15	PI	RF-24, RF-25	Actualización de contenido publicado y tolerancia a fallos mostrando la última versión.
CP-16	CN	RF-26, RNF-08	Modo avión: contenido completo disponible con carga ≤ 2 s.
CP-17	CN + US	RF-27, RF-28	Cuestionario navegable con abandono sin persistencia; descarte de respuestas con salida rápida.
CP-18	CN	RF-29, RF-30	Nivel orientativo correcto según respuestas, accesos a rutas y aviso visible sin desplazamiento.
CP-19	CN + PS	RF-31	El resultado solo persiste con confirmación expresa; descartar no deja registro.
CP-20	PU + CN	RF-32	Registro de incidente con validación de obligatorios sin pérdida de lo diligenciado.
CP-21	PI	RF-33	Evidencias adjuntas protegidas y visibles solo dentro de Aurora.
CP-22	PU + CN	RF-34, RF-35, RF-36	Listado cronológico, edición persistida y eliminación con doble confirmación incluyendo evidencias.
CP-23	PI + PS	RF-37, RF-38	Sincronización por canal seguro con acceso restringido; cola de cambios sin conexión.
CP-24	CN	RF-39	Recuperación íntegra de registros y evidencias en un segundo dispositivo.
CP-25	PS	RF-40	Acceso al panel con rol de administradora; denegación a cuentas sin rol.
CP-26	CN	RF-41, RF-42, RF-44	Gestión de contenido y rutas, integridad al eliminar entidades y reflejo de lo publicado en la app.
CP-27	CN	RF-43	Gestión del cuestionario y bloqueo de publicaciones incompletas.
CP-28	PS	RNF-01	Cifrado: almacenamiento ilegible sin llave y tráfico sin datos en claro.
CP-29	PS	RNF-02	Bloqueo de capturas y ocultamiento en aplicaciones recientes.
CP-30	PS	RNF-03	Cierre automático de sesión a los 5 minutos de inactividad.
CP-31	PS	RNF-04	Auditoría del almacenamiento contra el inventario de datos aprobado.
CP-32	PS	RNF-05	Lista de verificación de camuflaje aplicada ítem por ítem.
CP-33	PS	RNF-06	Separación de acceso: petición administrativa a datos de usuarias rechazada.
CP-34	PI	RNF-07	Arranque ≤ 3 s e interacciones locales ≤ 2 s en dispositivo de gama media.
CP-35	US	RNF-09	Evaluación heurística sin hallazgos de severidad ≥ 3 pendientes (prototipos y app).
CP-36	PI	RNF-10	Ejecución en la versión mínima de Android definida y en dispositivo reciente.
CP-37	Revisión	RNF-11	Revisión de arquitectura por capas y muestreo de documentación.
CP-38	PI + CN + PS	RF-45	Exportación de registros a PDF con contraseña y nombre neutro, con y sin adjuntos, sin permisos nuevos, sin copias en la app y con captura bloqueada.

Caso	Tipo	Requerimientos	Qué verifica
CP-39	PU + CN + PS	RF-46	Recuperación de contraseña por correo: mensaje idéntico exista o no la cuenta, aviso previo, pausa tras varios envíos, aviso sin conexión y correo sin términos ajenos a la identidad de clima.

Nota. Elaboración propia a partir del plan de pruebas del proyecto. PU: prueba unitaria; PI: prueba de integración; CN: prueba de caja negra; PS: prueba de seguridad; US: prueba de usabilidad.

3.5 Elementos no probados y riesgos

Quedaron fuera del plan el rendimiento en teléfonos físicos de gama media, que se midió en emulador; la activación de la versión de publicación en una instalación limpia, que solo puede activarse a partir de la versión de depuración; el comportamiento con teclados distintos al de Google; las defensas contra la ingeniería inversa, es decir, contra alguien que descompila el instalable para estudiar su código, porque la amenaza principal de Aurora es una persona del entorno de la usuaria que toma el teléfono (sección 5.1); y la carga simultánea sobre los servicios en la nube, que funcionan en su capa gratuita. El principal riesgo del plan es que el emulador no reproduzca el comportamiento de los teléfonos de las usuarias; por eso los recorridos manuales también se hicieron en un teléfono físico y los elementos no probados se registran como pendientes antes de un piloto (sección 8).

4. Pruebas técnicas

4.1 Funcionalidad

Cada caso se verificó con pruebas automáticas, con recorridos manuales en emuladores o con ambos, y en la versión final todos los casos ejecutados pasaron. La Tabla 2 resume la suite automática de la v0.3.4-trl4. Entre la v0.3.1 y la v0.3.4 las pruebas unitarias pasaron de 802 a 1068 y las instrumentadas de 47 a 199, porque cada corrección de la evaluación heurística y la guía «Cómo usar Aurora» entraron con sus propias pruebas.

Tabla 2

Pruebas automáticas de la versión final

Tipo de prueba	Cantidad	Resultado
Pruebas unitarias de la aplicación	1068	Sin fallos, en la variante de depuración y en la de publicación
Pruebas instrumentadas en emulador	199	Sin fallos en Android 11 y en Android 8.0; en Android 8.0 se omite una variante que usa un gesto que no existe en esa versión
Pruebas del panel web	91	Sin fallos
Análisis de estilo (ktlint) y Android Lint	—	Sin errores
Guardián de camuflaje sobre el instalable de publicación	—	Sin términos vedados

Nota. Elaboración propia a partir de los resultados de pruebas del proyecto.

Además de verificar los requerimientos, varias pruebas automáticas vigilan el camuflaje y la seguridad en todo el código: que ningún texto de la aplicación delate su propósito, que ninguna pantalla del espacio privado quede sin el bloqueo de capturas, que el manifiesto no pida permisos innecesarios y que nada sensible se escriba en los registros del sistema. En cada compilación de la versión de publicación, el guardián de camuflaje busca en el instalable palabras que puedan revelar el propósito de la aplicación.

Los recorridos manuales siguieron una lista única: instalación y camuflaje, uso de los tres módulos, restauración en un segundo dispositivo, cambio y recuperación de la contraseña, actualización desde una versión anterior con datos guardados, el panel web y la eliminación total de la cuenta. En la corrida de cierre de cada versión todos los recorridos pasaron. Para la versión final, la investigadora repitió además a mano, en un teléfono Xiaomi, el recorrido de «Cómo usar Aurora»: el orden de los pasos, la salida real con la nube y la reentrada, la reapertura desde Ajustes, el lector de pantalla y la vista de aplicaciones recientes, sin encontrar fallos.

4.2 Rendimiento

Las pruebas de rendimiento se hicieron sobre la versión de publicación v0.3.1-trl4, en un emulador configurado como un teléfono de gama media (Pixel 2 con Android 11, 2 GB de memoria y cuatro núcleos). El arranque se midió con las herramientas del sistema, y las transiciones con mediciones dentro del dispositivo. La Tabla 3 presenta los resultados frente a los límites del requerimiento no funcional de rendimiento.

Tabla 3

Tiempos medidos en un emulador de gama media

Acción	Resultado	Límite
Arranque en frío, con conexión (tres veces)	0,27 · 0,23 · 0,23 s	3 s
Arranque en frío, sin conexión (tres veces)	0,21 · 0,22 · 0,22 s	3 s
Entrada al espacio privado con el código de acceso	Menos de 0,5 s	2 s
Cambio entre pestañas	Entre 0,06 y 0,07 s	2 s
Salida rápida al clima	Entre 0,04 y 0,07 s	1 s
Guardar un registro con cuatro adjuntos	Cerca de 1,2 s	2 s
Generar el PDF con cuatro adjuntos	1,16 s, sin bloqueos	2 s
Desplazamiento de la Guía	Ningún cuadro perdido	Sin saltos visibles

Nota. Elaboración propia. Los tiempos de entrada y de salida rápida son cotas inferiores, porque se midieron con el cambio del bloqueo de capturas, que ocurre justo antes de que la pantalla se dibuje.

Todos los tiempos quedaron muy por debajo de los límites. Estas mediciones tienen tres limitaciones. La primera es que el emulador corre sobre un computador más potente que un teléfono de gama media, por lo que los tiempos son una referencia y deben confirmarse en teléfonos reales antes de un piloto. La segunda es que el desplazamiento solo se midió en la Guía, no en el listado de registros ni en el pronóstico. La tercera es que los cuatro adjuntos del PDF fueron imágenes; no se midieron documentos ni audios adjuntos. Las mediciones no se

repitieron en las versiones siguientes, porque ninguna cambió la arquitectura ni el almacenamiento. En la v0.3.4 el cálculo del código de acceso pasó del hilo principal a un hilo aparte, después de que una corrida con el computador anfitrión cargado mostrara que escribir rápido en el buscador podía bloquear la interfaz; con el cambio, la misma corrida no registró ningún bloqueo.

4.3 Compatibilidad

La compatibilidad se verificó en un emulador con Android 8.0, la versión mínima que soporta la aplicación. Se recorrió el flujo completo sin cierres inesperados: la pantalla de clima, la activación, el recorrido de primer uso, la guía, el cuestionario con un resultado guardado, la restauración desde la nube de un registro con sus cuatro adjuntos, y la exportación y el envío del PDF. El bloqueo de capturas funcionó y las pantallas se vieron sin deformaciones.

En esta versión de Android, la vista de aplicaciones recientes puede mostrar el texto que se estaba escribiendo en la barra de búsqueda, porque la función del sistema que permite ocultarlo solo existe desde Android 13. En la prueba ocurrió en tres de cuatro intentos. Es una limitación conocida para las versiones anteriores a Android 13 y está registrada en la documentación del proyecto.

En la v0.3.2, las pruebas instrumentadas en emuladores con Android 8.0 y 8.1 detectaron un defecto de esas versiones del sistema: el cifrado del almacén de llaves devolvía salidas incompletas, sin ningún error, cuando una sola escritura superaba unos 128 KB, lo que afectaba el guardado de adjuntos grandes. Se corrigió escribiendo los adjuntos por trozos de 32 KB y verificando cada adjunto después de cifrarlo (hallazgo H-12 de la Tabla 5). Desde esa versión, la suite instrumentada completa se ejecuta en Android 11 y en Android 8.0 en cada cierre de versión, y en la v0.3.4 las 199 pruebas pasaron en los dos.

5. Evaluación de seguridad

5.1 Marco y alcance

La seguridad se evaluó con el marco OWASP MAS, que tiene dos partes: el estándar MASVS, que define los controles que una aplicación móvil debe cumplir, y la guía MASTG, que describe cómo probar cada uno. Se usaron las versiones vigentes, MASVS 2.1.0 (OWASP Foundation, 2024) y MASTG 2.0.0 (OWASP Foundation, 2026).

De las ocho categorías del estándar se evaluaron siete. La de resiliencia, que trata de defensas contra la ingeniería inversa, se dejó fuera porque protege contra un analista experto con herramientas especializadas, mientras que la amenaza principal de Aurora es una persona del entorno de la usuaria que toma el teléfono. Así, de los 24 controles del estándar quedaron 20 en alcance. Tres no aplicaban a Aurora, porque la aplicación no usa páginas web embebidas, no tiene servidores propios a los que fijar certificados y no se distribuye por una tienda de aplicaciones, y quedaron 17 controles evaluables.

5.2 Método

La evaluación combinó tres tipos de revisión. En el análisis estático se descompiló el instalable para revisar su manifiesto, su código y sus recursos, y buscar contraseñas o llaves expuestas. En el análisis dinámico se instaló la aplicación en un emulador con una cuenta de prueba y se revisó lo que escribe en el teléfono y lo que muestra en pantalla. Además, se ejecutaron de nuevo las pruebas automáticas del proyecto y se probaron las reglas de acceso de la base de datos en la nube con el emulador local de Firestore. La evaluación completa se hizo sobre la versión v0.3.0 y se verificó de nuevo sobre la v0.3.1, después de corregir los hallazgos; en las versiones v0.3.2, v0.3.3 y v0.3.4 se revisaron los controles que tocaba cada cambio, con una revisión de seguridad por bloque de trabajo.

5.3 Resultados

Tabla 4

Resultados de la evaluación OWASP MASVS antes y después de las correcciones

Resultado	Evaluación inicial (v0.3.0-trl4)	Tras las correcciones (v0.3.1-trl4 a v0.3.4-trl4)
Pasa	7	7
Pasa con observación	9	10
Falla	1	0
No aplica	3	3
Total en alcance	20	20

Nota. Elaboración propia a partir del informe de seguridad del proyecto. «Pasa con observación» indica que el control se cumple, pero con una salvedad documentada. Las re-verificaciones de las versiones v0.3.2, v0.3.3 y v0.3.4 mantuvieron el mismo recuento. Con lo que se supo después, en la v0.3.1 dos controles, el de autenticación y el de criptografía, habrían quedado con observación por los hallazgos H-11 y H-12, que se encontraron y corrigieron en la v0.3.2.

La evaluación confirmó que los mecanismos centrales de protección funcionan como se diseñaron. Las bases de datos de los registros y de los resultados del cuestionario no mostraron ninguna palabra legible, las evidencias adjuntas estaban cifradas y los siete documentos PDF exportados durante las pruebas tenían el cifrado más fuerte que admite ese formato. La captura del espacio privado salió completamente negra, la vista de aplicaciones recientes salió en blanco y la aplicación volvió sola al clima tras cinco minutos y cuarenta segundos de inactividad. Las ocho pruebas de las reglas de la base de datos en la nube pasaron, incluida la que confirma que una cuenta administradora no puede leer los datos de una usuaria.

Se registraron doce hallazgos: siete en la evaluación inicial, tres en la verificación de las correcciones de la v0.3.1 y dos en la re-verificación de la v0.3.2. La Tabla 5 los resume.

Tabla 5

Hallazgos de la evaluación de seguridad

Código	Hallazgo	Gravedad	Estado
H-7	El texto del relato se podía copiar y pegar en otra aplicación mientras se escribía.	Alta	Corregido
H-9	Los campos del código de acceso y las contraseñas se podían copiar al mostrar el texto con el ícono del ojo.	Alta	Corregido
H-10	El teclado sugería, en el buscador del clima, un código de acceso que había aprendido.	Alta	Corregido
H-1	Nombres internos legibles en el instalable, entre ellos uno con la palabra «Secret».	Media	Corregido
H-2	Cierre inesperado al salir de una pantalla con texto escrito, causado por una librería de Google.	Media	Corregido
H-8	Expresión en inglés asociada a la salida rápida legible en el instalable.	Media	Corregido
H-11	La activación aceptaba la sesión de un registro de cuenta que se había interrumpido antes de crear el código de acceso.	Media	Corregido en la v0.3.2
H-3	Instalable firmado con la clave de pruebas.	Baja	Pendiente antes de un piloto
H-4	Dos componentes expuestos de la librería de autenticación que la aplicación no usa.	Baja	Pendiente antes de un piloto
H-5	Falta de una configuración de red explícita.	Baja	Corregido
H-12	En Android 8.0 y 8.1, el cifrado de los adjuntos devolvía salidas incompletas cuando una sola escritura superaba unos 128 KB.	Baja	Corregido en la v0.3.2
H-6	Comprobaciones que solo se podían hacer a mano: aprendizaje del teclado y copia de texto.	Informativa	Cerrado

Nota. Elaboración propia a partir del informe de seguridad del proyecto. Los hallazgos están ordenados por gravedad; el número de cada código indica el orden en que se encontraron.

El hallazgo H-7 fue la causa del único control que falló en la evaluación inicial, el de protección de datos sensibles. En la versión corregida se quitaron las opciones de copiar y cortar en el relato y en los campos del código de acceso y las contraseñas, se le indicó al teclado que no

memorizara lo escrito y se desactivaron sus sugerencias en las barras de búsqueda. Esta última corrección se comprobó con el teclado de Google; los teclados de otras marcas no se probaron.

Con las correcciones, los 17 controles evaluables se cumplieron. El control de protección de datos sensibles conservó dos observaciones: la copia local que Firestore guarda para funcionar sin conexión no tiene la misma protección que el resto de los datos, y un servicio de accesibilidad, como un lector de pantalla, puede leer y copiar el texto del relato. Esta segunda observación también se registró en el control de uso seguro de la interfaz. El lector de pantalla no se bloquea, porque eso dejaría el relato inaccesible para quien lo necesite. En la re-verificación de la v0.3.4, la auditoría dejó dos observaciones residuales sobre la eliminación total de la cuenta: una consulta del código de acceso en el instante del borrado puede volver a crear la llave del código, y el borrado de la llave puede continuar aunque se cancele. Ninguna de las dos cambia el resultado de un control; quedaron registradas para resolverlas antes de un piloto.

5.4 Protección de datos personales y referencia a ISO/IEC 27001

Los resultados también se revisaron frente a la Ley 1581 de 2012. El principio de libertad se cumple con el consentimiento informado que la usuaria acepta antes del cuestionario y con la decisión, siempre suya, de guardar o no cada resultado. El de finalidad se refleja en la minimización de datos: la aplicación solo guarda lo necesario para cada función, no pide permisos de ubicación, contactos, cámara ni almacenamiento y no usa servicios de analítica. Los de seguridad y confidencialidad se cumplen con el cifrado de los datos en el teléfono y en la nube, y el de acceso y circulación restringida con las reglas de la base de datos, que solo permiten a cada usuaria leer sus propios datos; ni siquiera la cuenta administradora puede hacerlo. Además, la usuaria puede editar o eliminar sus registros y eliminar por completo su cuenta con todos sus datos, lo que corresponde a los derechos de rectificación y supresión que la

ley reconoce. Una implementación real necesitaría además una política de tratamiento de datos y los procedimientos formales que exige la ley, que no hacen parte de un prototipo.

La norma ISO/IEC 27001 (International Organization for Standardization & International Electrotechnical Commission, 2022) define requisitos para el sistema de gestión de seguridad de la información de una organización, por lo que no se aplica como certificación a una aplicación. Se usó como referencia de los controles de su anexo A que corresponden al desarrollo de software. El uso de criptografía (control 8.24), el control de acceso (5.15) y la autenticación segura (8.5) están cubiertos por el cifrado, las reglas de acceso de la base de datos y el ingreso con código de acceso y contraseña. El ciclo de desarrollo seguro (8.25), la codificación segura (8.28) y las pruebas de seguridad (8.29) se reflejan en la revisión de seguridad de cada bloque de trabajo y en la evaluación OWASP descrita en este capítulo.

6. Evaluación de usabilidad

6.1 Instrumento y meta

La usabilidad percibida se midió con la System Usability Scale (SUS), un cuestionario de diez afirmaciones que la persona califica de 1 (totalmente en desacuerdo) a 5 (totalmente de acuerdo) después de usar un sistema (Brooke, 1996). Las afirmaciones impares están redactadas en sentido positivo y las pares en sentido negativo, lo que obliga a leer cada una con atención. Es una escala corta, de uso libre y muy empleada para comparar la usabilidad de aplicaciones, aunque no sirve para diagnosticar problemas concretos (Sauro, 2011); por eso se complementó con la finalización de las tareas y con tres preguntas abiertas. Se usó una traducción al español que retoma las decisiones de la versión validada por Sevilla-Gonzalez et al. (2020), como «personal experto» en la afirmación 4 y «tediosa» en la afirmación 8, y que reemplaza «sistema» por «aplicación». La meta del proyecto es un puntaje promedio igual o mayor a 75 sobre 100. Siguiendo ISO 9241-11 (International Organization for Standardization,

2018), la usabilidad se valoró por la satisfacción, con la SUS, y por la eficacia, con la finalización de las tareas.

6.2 Participantes

Participaron diez personas mayores de edad, entre el 3 y el 7 de noviembre de 2026: dos de 18 a 20 años, cinco de 21 a 23, una de 24 a 26 y dos de 27 o más. Ocho usan un teléfono Android y dos un iPhone. A nadie se le preguntó por experiencias personales de violencia.

6.3 Materiales y desarrollo de la sesión

Las ocho participantes con Android hicieron la prueba en su propio teléfono y las dos con iPhone, en un teléfono Xiaomi de la investigadora. En todos se instaló como nueva la versión de depuración del prototipo, v0.3.4, para que cada participante hiciera el primer uso completo, con la imagen de prueba disponible para el adjunto. A cada participante se le asignó un código (P01 a P10) en el orden de las respuestas, y para crear la cuenta de prueba usó su primer nombre seguido de @aurora.test. Su nombre solo quedó en el formulario, para organizar las respuestas, y no aparece en los resultados.

La sesión se apoyó en un formulario de Google Forms, que reunió el consentimiento (S1), los datos de prueba y la persona simulada (S2), las tareas (S3) y el cuestionario con las preguntas abiertas (S4); la participante marcaba en el formulario cada tarea al terminarla. Los instrumentos están en el Apéndice A. Si la aplicación volvía sola al clima porque pasaban cinco minutos sin usarla, se explicaba que es una protección de la aplicación y que se podía entrar de nuevo con el código de acceso. Las sesiones no se grabaron, y además el sistema impide capturar la pantalla del espacio privado. La Tabla 6 presenta las tareas.

Tabla 6

Tareas de la sesión de usabilidad

Tarea	Descripción
T1	Busca la ciudad de Bucaramanga y mira el pronóstico de los próximos cinco días.
T2	Escribe el código de activación de la tarjeta en el buscador de ciudades. Acepta el consentimiento, crea tu cuenta con el correo y la contraseña de la tarjeta, crea tu clave personal y completa el tutorial.
T3	Sal rápido de la aplicación para que solo se vea el clima. Luego vuelve a entrar a tu espacio.
T4	Busca qué es la violencia psicológica y a qué entidad podría acudir Valentina en Floridablanca para pedir medidas de protección.
T5	Responde el cuestionario de la aplicación como si fueras Valentina, mira el resultado y guárdalo.
T6	Anota en tu registro el hecho de Valentina, con la fecha, el tipo y una descripción corta, y adjunta la imagen de prueba de la galería.
T7	Exporta ese registro a un archivo PDF protegido con la contraseña de la tarjeta.

Nota. Elaboración propia. Las tareas recorren el primer uso y las funciones principales; aparecen en orden en el formulario y la participante las marcó a medida que las terminaba

6.4 Cálculo e interpretación del puntaje

El cuestionario se responde justo después de las tareas y antes de cualquier conversación sobre la aplicación. El puntaje de cada participante se calcula así (Brooke, 1996): en las afirmaciones impares se resta 1 a la respuesta; en las pares se resta la respuesta a 5; los diez valores resultantes, cada uno entre 0 y 4, se suman, y la suma se multiplica por 2,5. El resultado va de 0 a 100. El puntaje del prototipo es el promedio de los puntajes de todas las participantes, y se reporta con su desviación estándar, su intervalo de confianza del 95 %, el mínimo y el máximo. El puntaje no es un porcentaje: el promedio de cerca de 500 estudios con SUS es 68 (Sauro, 2011), y Bangor et al. (2009) encontraron que los sistemas calificados como «buenos» promediaron 71,4 y los calificados como «excelentes», 85,5. La meta de 75 queda por encima del promedio y en la franja de una usabilidad buena.

6.5 Resultados

Las diez participantes completaron las siete tareas y respondieron el cuestionario. El puntaje SUS promedio fue de 93,25 sobre 100, con una desviación estándar de 5,78 y un intervalo de confianza del 95 % de 89,1 a 97,4. El puntaje más bajo fue 82,5 y el más alto, 100, y las diez participantes superaron la meta de 75 (Tabla 7). El límite inferior del intervalo queda por encima de la meta y del promedio de 85,5 que Bangor et al. (2009) encontraron en los sistemas calificados como excelentes.

Tabla 7

Puntaje SUS por participante

Participante	Edad	Puntaje SUS
P01	21 a 23	100
P02	24 a 26	95
P03	18 a 20	90
P04	27 o más	97,5
P05	21 a 23	100
P06	21 a 23	90
P07	27 o más	87,5
P08	21 a 23	92,5
P09	21 a 23	82,5
P10	18 a 20	97,5

Nota. Elaboración propia a partir de las respuestas del formulario. El cálculo está en el anexo Aurora_Fase4_Calculo_SUS.xlsx.

Por afirmación, las mejor calificadas fueron la 5, sobre la integración de las funciones, y la 9, sobre la confianza al usar la aplicación, con un promedio de 4,9 sobre 5; en las afirmaciones 6 y 8, sobre inconsistencia y tedio, todas las participantes marcaron «totalmente en desacuerdo». La afirmación con el resultado menos favorable fue la 10, «Necesité aprender

muchas cosas antes de poder empezar a usar esta aplicación», con un promedio de 1,9, seguida de la 3, sobre la facilidad de uso, con 4,4.

En las preguntas abiertas, seis participantes consideraron que una persona que tomara el teléfono pensaría que es solo una aplicación de clima, porque al buscar una ciudad la aplicación responde como tal y el espacio privado exige un código. Tres opinaron lo contrario por la identidad visual: el diseño les pareció femenino, el nombre y el ícono llamativos, o la aplicación de clima poco común; una no respondió. Ocho participantes no señalaron dificultades; una sugirió más ayuda dentro de cada sección y otra mencionó que al principio podría no entenderse cómo volver a entrar con el código de acceso. Las sugerencias fueron poder marcar más de un tipo de violencia en un registro, un video tutorial y más información del clima para reforzar el camuflaje.

Ningún comentario señaló un error ni impidió completar una tarea, por lo que el prototipo no se modificó después de las sesiones. Las observaciones sobre la identidad visual y las sugerencias se registran como pendientes antes de un piloto (sección 8).

7. Nivel de madurez alcanzado

La meta del proyecto es el TRL 4, validación del desarrollo en entorno de laboratorio, según la escala de MinCiencias: componentes integrados y funcionando en conjunto, con una unidad de prototipo validada en un entorno controlado. Las pruebas técnicas y la evaluación de seguridad muestran que los tres módulos funcionan integrados, que el prototipo cumple los 46 requerimientos funcionales y que los controles de seguridad aplicables se cumplen en la versión final.

La evaluación de usabilidad completa la validación: con un puntaje SUS promedio de 93,25, por encima de la meta de 75, y con todas las tareas completadas, el prototipo alcanza el nivel TRL 4, con sus componentes integrados y la unidad completa validada en un entorno controlado con datos simulados.

8. Conclusiones y pendientes antes de un piloto

El prototipo cumplió las pruebas de funcionalidad, de rendimiento y de compatibilidad, y los 17 controles de seguridad aplicables del estándar OWASP MASVS en su versión final, la v0.3.4-trl4. La evaluación de usabilidad dio un puntaje SUS promedio de 93,25, por encima de la meta de 75, y las diez participantes completaron todas las tareas. La evaluación de seguridad encontró problemas reales que no se habían previsto, en particular formas de sacar texto protegido del espacio privado, y todos los de gravedad alta y media se corrigieron. Las tres versiones posteriores a la evaluación completa se revisaron control por control en cada cambio, sin hallazgos nuevos que cambiaran el resultado. Ninguno de los pendientes compromete la confidencialidad de los datos ni rompe el camuflaje frente a la amenaza planteada en el proyecto, por lo que se consideran aceptables para un prototipo en nivel TRL 4.

Antes de un piloto con usuarias quedan las siguientes tareas:

- Medir los tiempos de respuesta en teléfonos reales de gama media.
- Firmar el instalable con una clave propia (H-3).
- Retirar los componentes de la librería de autenticación que la aplicación no usa (H-4), y revisar una actividad de prueba que solo aparece en la versión de depuración.
- Implementar la activación en la versión de publicación, que hoy solo puede activarse con la versión de depuración.
- Cerrar las dos observaciones residuales de la eliminación total de la cuenta: que solo la creación del código de acceso genere su llave, y que el borrado de la llave respete la cancelación.
- Que una activación interrumpida no deje rastro de la cuenta ni datos en la caché de la nube, y que el cambio de cuenta en un mismo teléfono no mezcle los registros de dos personas.

- Desactivar el registro abierto de cuentas en Firebase y evaluar la verificación de integridad de la aplicación.
- Repetir la comprobación del teclado con los teclados de fábrica de los teléfonos del piloto.
- Revisar la identidad visual de la fachada (nombre, ícono y paleta) para que no se distinga de una aplicación de clima común, y ampliar la información del clima.
- Permitir marcar más de un tipo de violencia en un registro y ampliar la ayuda dentro de cada sección, por ejemplo con un video corto.
- Evaluar la usabilidad con mujeres del perfil de la usuaria, con la aprobación de un comité de ética en investigación, y medir también el tiempo de cada tarea.

Referencias

Bangor, A., Kortum, P., & Miller, J. (2009). Determining what individual SUS scores mean: Adding an adjective rating scale. *Journal of Usability Studies, 4*(3), 114–123.

Brooke, J. (1996). SUS: A “quick and dirty” usability scale. En P. W. Jordan, B. Thomas, B. A. Weerdmeester, & I. L. McClelland (Eds.), *Usability evaluation in industry* (pp. 189–194). Taylor & Francis.

International Organization for Standardization. (2018). *ISO 9241-11:2018. Ergonomics of human-system interaction — Part 11: Usability: Definitions and concepts.*

International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.*

International Organization for Standardization & International Electrotechnical Commission. (2023). *ISO/IEC 25010:2023. Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model.*

International Organization for Standardization, International Electrotechnical Commission & Institute of Electrical and Electronics Engineers. (2021). *ISO/IEC/IEEE 29119-3:2021. Software and systems engineering — Software testing — Part 3: Test documentation.*

Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. (2012). Congreso de la República de Colombia.

OWASP Foundation. (2024). *OWASP Mobile Application Security Verification Standard (MASVS)* (Versión 2.1.0). https://mas.owasp.org/MASVS/

OWASP Foundation. (2026). *OWASP Mobile Application Security Testing Guide (MASTG)* (Versión 2.0.0). https://mas.owasp.org/MASTG/

Sauro, J. (2011). *Measuring usability with the System Usability Scale (SUS).* MeasuringU. https://measuringu.com/sus/

Sevilla-Gonzalez, M. D. R., Moreno Loaeza, L., Lazaro-Carrera, L. S., Bourguet Ramirez, B., Vázquez Rodríguez, A., Peralta-Pedrero, M. L., & Almeda-Valdes, P. (2020). Spanish version of the System Usability Scale for the assessment of electronic tools: Development and validation. *JMIR Human Factors, 7*(4), e21161. https://doi.org/10.2196/21161

Apéndice A. Instrumentos de la evaluación de usabilidad

Los instrumentos S1 a S4 se respondieron en el formulario de Google Forms. La tarjeta de datos de prueba se presenta sin sus valores.

Instrumento S1. Consentimiento informado

Evaluación de usabilidad del prototipo Aurora

Te invito a participar en la evaluación de una aplicación móvil desarrollada como trabajo de grado de Ingeniería de Sistemas en la Universidad Autónoma de Bucaramanga, por Leydy Yohana Macareo Fuentes, bajo la dirección de Verónica Chajín Ortiz.

Qué harás. Usarás la aplicación en un teléfono de la investigadora para hacer siete tareas cortas, como si fueras una persona inventada, y después responderás un cuestionario de diez afirmaciones y tres preguntas abiertas. La sesión dura unos 30 minutos.

Sobre el contenido. La aplicación trata sobre violencia de género. No se te preguntará por experiencias personales y todos los datos que escribirás son inventados. Si en algún momento te sientes incómoda, puedes parar.

Tu participación es voluntaria. Puedes no participar o retirarte en cualquier momento, sin dar explicaciones y sin ninguna consecuencia.

Tus datos. Tu nombre se pide solo para organizar las respuestas y no aparecerá en los resultados, que se presentarán agrupados. No se tomarán fotos, videos ni grabaciones. La información se usará solo con fines académicos, conforme a la ley de protección de datos personales (Ley 1581 de 2012).

Contacto. Si tienes preguntas, puedes escribir a la investigadora al correo lmacareo456@unab.edu.co.

☐ He leído esta información, mis preguntas fueron respondidas y acepto participar de forma voluntaria. Declaro que soy mayor de edad.

Firma: _____ Fecha: _____ Código: P____

Instrumento S2. Tarjeta de datos de prueba

Participante: P____ Fecha: _____

Dato	Valor
Código de activación	_____
Correo para crear la cuenta	Tu primer nombre, en minúsculas y sin tildes, seguido de @aurora.test (por ejemplo, maria@aurora.test)
Contraseña de la cuenta	_____
Código de acceso	_____
Contraseña del PDF (tarea T7)	_____

Persona simulada

Valentina, 22 años, vive en Floridablanca. Estudia y trabaja medio tiempo. Desde hace unos meses su pareja revisa su teléfono, le pide las contraseñas de sus redes sociales y se enoja si sale con sus amigas. Le escribe muchas veces al día para saber dónde está. Nunca la ha golpeado, pero a veces la insulta cuando discuten. Valentina no está segura de si lo que vive es violencia.

Hecho para registrar: el 3 de octubre, su pareja le quitó el teléfono, leyó sus conversaciones y le dijo que si volvía a hablar con un compañero de clase iba a terminar con ella. Tipo: violencia psicológica.

Todos estos datos son inventados. No escribas en la aplicación información real tuya ni de otras personas.

Instrumento S3. Tareas

Hazlas en orden. No hay respuestas buenas ni malas: si algo no te sale, es un problema de la aplicación y nos sirve saberlo.

Tarea	Qué hacer
T1	Busca la ciudad de Bucaramanga y mira el pronóstico de los próximos cinco días.
T2	Escribe el código de activación en el buscador de ciudades. Avanza desde la bienvenida, acepta el consentimiento, crea tu cuenta con el correo y la contraseña de la tarjeta, y crea tu código de acceso.
T3	Sigue los ocho pasos de «Cómo usar Aurora». En el paso 8, toca la nube para salir al clima y vuelve a entrar con tu código de acceso, hasta que aparezca la pantalla «¡Listo!».
T4	Busca qué es la violencia psicológica y a qué entidad podría acudir Valentina en Floridablanca para pedir medidas de protección.
T5	Responde el cuestionario como si fueras Valentina, mira el resultado y guárdalo.
T6	Anota en tu registro el hecho de Valentina, con la fecha, el tipo y una descripción corta, y adjunta la imagen de prueba de la galería.
T7	Exporta ese registro a un archivo PDF protegido con la contraseña de la tarjeta.

Instrumento S4. Cuestionario

Participante: P____ Fecha: _____

Edad: ☐ 18 a 20 ☐ 21 a 23 ☐ 24 a 26 ☐ 27 o más

Tu teléfono es: ☐ Android ☐ iPhone ☐ Otro

Marca con una X qué tan de acuerdo estás con cada afirmación sobre la aplicación que acabas de usar. Responde todas, con tu primera impresión. Si no sabes qué responder en alguna, marca el 3.

N.°	Afirmación	1	2	3	4	5
1	Creo que me gustaría usar esta aplicación con frecuencia.					
2	Encontré la aplicación innecesariamente compleja.					
3	Pensé que la aplicación era fácil de usar.					
4	Creo que necesitaría el apoyo de personal experto para poder usar esta aplicación.					
5	Encontré que las diversas funciones de la aplicación estaban bien integradas.					
6	Pensé que había demasiada inconsistencia en la aplicación.					
7	Imagino que la mayoría de las personas aprenderían a usar esta aplicación muy rápidamente.					
8	Encontré la aplicación muy tediosa de usar.					
9	Me sentí con mucha confianza al usar la aplicación.					
10	Necesité aprender muchas cosas antes de poder empezar a usar esta aplicación.					

1 = Totalmente en desacuerdo · 2 = En desacuerdo · 3 = Ni de acuerdo ni en desacuerdo · 4 = De acuerdo · 5 = Totalmente de acuerdo

Preguntas abiertas

1. ¿Qué fue lo más difícil o confuso de usar la aplicación?

_____

_____

2. ¿Qué cambiarías o agregarías?

_____

_____

3. Si otra persona tomara el teléfono, ¿crees que pensaría que es solo una aplicación de clima? ¿Por qué?

_____

Anexos digitales

Los siguientes archivos acompañan este documento en la carpeta «anexos digitales/fase 4» de la entrega, publicada en github.com/leydymf/aurora-entregables. Los archivos marcados como del repositorio están en github.com/leydymf/aurora-app.

Archivo	Contenido
Aurora_Fase4_Calculo_SUS.xlsx	Hoja de cálculo del puntaje SUS con las respuestas de las diez participantes, identificadas por código
Aurora_Fase4_Formulario_SUS.gs	Script con que se creó el formulario de la sesión en Google Forms
docs/PLAN_PRUEBAS.md y docs/RESULTADOS_PRUEBAS.md (repositorio)	Plan de pruebas completo y resultados de cada corrida, por versión
docs/INFORME_SEGURIDAD_OWASP.md y docs/evidencias-owasp/ (repositorio)	Evaluación de seguridad completa, control por control, con sus evidencias y re-verificaciones
aurora-clima-0.3.4.apk	Instalable de depuración usado en las sesiones (SHA-256 e8a28b98…1da3559)